

Clase 316 — Modelos de seguridad y arquitectura (Bell-LaPadula, Biba, Clark-Wilson)

Parte: **17 — Profundización para certificaciones** · Fuente: (ISC)² CISSP Official Study Guide, 9.^a ed. — Chapple, Stewart & Gibson 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

Objetivo

Entender los **modelos formales de seguridad** que fundamentan la arquitectura de sistemas confiables y traducir sus propiedades (confidencialidad, integridad, separación) a decisiones de diseño reales. Al terminar sabrás distinguir cuándo aplica Bell-LaPadula, Biba, Clark-Wilson o Brewer-Nash, y cómo se relacionan con conceptos de arquitectura como TCB, anillos de protección y el monitor de referencia — material central del dominio de *Security Architecture and Engineering* de CISSP.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

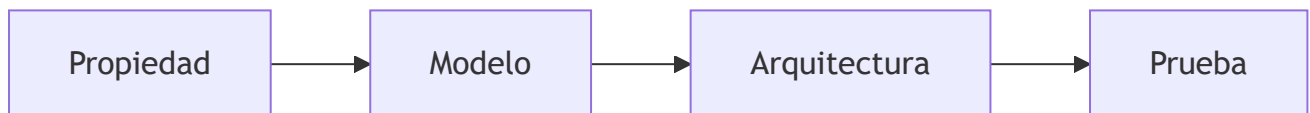
1. **Explicar** las propiedades formales de Bell-LaPadula (ss-property, *-property, ds-property) y Biba (simple/star integrity) sin confundir su dirección.
2. **Seleccionar** el modelo adecuado según el objetivo protegido (confidencialidad vs integridad vs conflicto de interés).
3. **Describir** los componentes de una TCB: monitor de referencia, kernel de seguridad y sus propiedades (aislamiento, completitud, verificabilidad).
4. **Relacionar** anillos de protección, modos de CPU y frontera de confianza con la superficie de ataque.
5. **Diseñar** una matriz de control de acceso multinivel que respete un modelo formal elegido.

Temas

#	Tema	Por qué importa
1	Máquina de estados y modelo de seguridad	Base formal: un sistema seguro solo transita entre estados seguros
2	Bell-LaPadula (BLP) — confidencialidad	Modelo "no leer arriba, no escribir abajo"; origen de MAC militar
3	Biba — integridad	Inverso de BLP: "no leer abajo, no escribir arriba"
4	Clark-Wilson — integridad comercial	TP/CDI/UDI y separación de deberes en transacciones
5	Brewer-Nash (Muralla China)	Conflicto de interés dinámico en consultoras
6	TCB, monitor de referencia y kernel de seguridad	Núcleo confiable que media todo acceso
7	Anillos de protección y modos de ejecución	Aislamiento por hardware entre kernel y usuario
8	Take-Grant, matriz de acceso, Graham-Denning	Modelos de derechos y su propagación

Modelo mental y caso de decisión

Los modelos formales explican propiedades bajo supuestos; arquitectura combina sujetos, objetos, flujos y fronteras reales.



Caso razonado. Bell-LaPadula protege confidencialidad pero no resuelve integridad operacional; se combinan controles.

Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Definiciones y características

- **Modelo de máquina de estados (state machine model):** representa el sistema como estados y transiciones; es *seguro* si siempre parte de un estado seguro y toda transición conduce a otro estado seguro. Característica clave: fundamento matemático de BLP y Biba.
- **Bell-LaPadula:** modelo de **confidencialidad** con etiquetas de sensibilidad. **Propiedad de seguridad simple (ss):** un sujeto no puede *leer* un objeto de nivel superior (*no read up*). **Propiedad estrella (*):** un sujeto no puede *escribir* a un nivel inferior (*no write down*). **Propiedad discrecional (ds):** el acceso también respeta una matriz de acceso. Característica clave: protege secretos, no la integridad.
- **Biba:** modelo de **integridad**, dual de BLP. **Simple integrity:** *no read down* (no leer de nivel de integridad menor). *** integrity:** *no write up* (no escribir a nivel mayor). Característica clave: evita contaminación de datos confiables por fuentes no confiables.
- **Clark-Wilson:** integridad comercial mediante **transacciones bien formadas**. Usa **CDI** (Constrained Data Items), **UDI** (Unconstrained Data Items), **TP** (Transformation Procedures) e **IVP** (Integrity Verification Procedures). Impone que los usuarios accedan a los datos *solo* a través de programas certificados. Característica clave: triple sujeto-programa-objeto y separación de deberes.
- **Brewer-Nash (Muralla China):** control de acceso **dinámico** que cambia según el historial de accesos del sujeto para evitar conflictos de interés. Característica clave: lo permitido depende de lo ya accedido.
- **TCB (Trusted Computing Base):** conjunto de hardware, firmware y software que hace cumplir la política de seguridad. Característica clave: todo lo confiable vive dentro de la frontera de confianza; reducirla reduce la superficie de ataque.
- **Monitor de referencia:** concepto abstracto que **media todo acceso** de sujetos a objetos. Debe ser: **a prueba de manipulación (tamperproof), siempre invocado (non-bypassable) y suficientemente pequeño para verificarse**. Su implementación es el **kernel de seguridad**.
- **Anillos de protección:** jerarquía (ring 0 = kernel, ring 3 = usuario en x86) que aísla por privilegio. Característica clave: el hardware evita que código de anillo externo acceda a recursos de anillo interno.

Herramientas y preparación

Esta es una clase conceptual; el "entorno" es de análisis y modelado:

- **Editor de diagramas:** draw.io / diagrams.net o Mermaid para dibujar retículos de niveles y flujos de datos.
- **Hoja de cálculo** (LibreOffice Calc / Excel) para construir matrices de acceso sujeto × objeto.
- **SELinux o AppArmor** en una VM Linux aislada para observar MAC real: `sestatus`, `seinfo`, `ls -Z` muestran etiquetas tipo Bell-LaPadula/Biba en producción.
- **Documento de referencia:** ten a mano el mapa de dominios CISSP (dominio 3) para ubicar cada modelo.

Recomendación: trabaja en una VM desechable (VirtualBox/Hyper-V) para experimentar con SELinux sin afectar tu sistema.



Laboratorio guiado — Diseñar una matriz de acceso multinivel

Ejercicio aplicado: modelarás un sistema de gestión documental de una agencia con cuatro niveles de sensibilidad y verificarás que cumple Bell-LaPadula.

1. **Define el retículo de niveles.** De menor a mayor: `Público < Interno < Confidencial < Secreto`. Documenta la relación de dominancia (cada nivel domina a los inferiores).
2. **Define sujetos y su clearance.** Ejemplo: `Ana=Secreto`, `Beto=Confidencial`, `Carla=Interno`, `Servicio_Web=Público`.
3. **Define objetos y su clasificación.** `plan_estrategico=Secreto`, `informe_finanzas=Confidencial`, `manual_rrhh=Interno`, `web_corp=Público`.
4. **Aplica ss-property (no read up).** Construye la matriz de *lectura*: marca ✓ solo si `clearance(sujeto) ≥ clasificacion(objeto)`. Verifica que Beto NO puede leer `plan_estrategico`.
5. **Aplica *-property (no write down).** Construye la matriz de *escritura*: marca ✓ solo si `clearance(sujeto) ≤ clasificacion(objeto)`. Verifica que Ana (Secreto) NO puede escribir en `web_corp` (Público) —evita fuga de información.
6. **Identifica el "tranquility principle".** Anota qué pasa si Beto es promovido a Secreto a mitad de sesión (strong vs weak tranquility) y por qué reetiquetar en caliente es riesgoso.
7. **Contrasta con Biba.** Reconstruye la matriz de escritura invirtiendo la regla (*no write up*) y observa cómo cambia el objetivo: ahora proteges integridad, no confidencialidad.
8. **Añade una regla Clark-Wilson.** Define un TP `aprobar_pago` que solo puede ejecutar un rol distinto al que lo crea (separación de deberes) y describe su IVP asociado.
9. **Documenta el resultado** en una tabla final con las dos matrices y una nota de qué modelo protege qué propiedad.

Entregable: un documento con el retículo, ambas matrices y la justificación del modelo.



Ejercicios

1. Dibuja el retículo de niveles de una empresa con las categorías `TLP: CLEAR/GREEN/AMBER/RED` y clasifica 5 documentos reales de tu organización.
2. Dado un sujeto `Confidencial` y un objeto `Secreto`, indica qué operaciones permite BLP y cuáles Biba, y explica la diferencia.
3. Modela con Clark-Wilson un flujo de "solicitud → aprobación → pago" identificando CDI, UDI, TP e IVP.
4. Explica con un caso de consultoría por qué Brewer-Nash es dinámico y BLP estático.
5. Enumera las tres propiedades del monitor de referencia y da un ejemplo de fallo real por incumplir cada una.
6. Argumenta por qué reducir la TCB mejora la verificabilidad, usando el kernel monolítico vs microkernel como ejemplo.



Reto verificable

Reto: entrega una matriz de acceso multinivel (lectura + escritura) para un sistema de 4 niveles y 4 sujetos que cumpla Bell-LaPadula, más una segunda versión Biba del mismo sistema.

Criterio de aceptación:

- Ninguna celda de lectura viola *no read up* y ninguna de escritura viola *no write down* en la versión BLP.
- La versión Biba invierte correctamente ambas reglas.
- Se identifica explícitamente qué propiedad de seguridad protege cada versión.
- Incluye al menos un TP con separación de deberes documentada (Clark-Wilson).

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Confundo la dirección de BLP y Biba"	Regla mnemónica: BLP protege C onfidencialidad → <i>no read up</i> ; Biba protege I ntegridad → <i>no read down</i> . Son duales.
"Creo que BLP protege integridad"	BLP solo protege confidencialidad; permite escribir hacia arriba, lo que degrada integridad. Usa Biba o Clark-Wilson para integridad.
"Aplico Clark-Wilson pero dejo acceso directo a los datos"	El modelo exige acceso solo vía TP certificados; el acceso directo a CDI rompe el modelo.
"Pongo todo el SO dentro de la TCB"	Inflar la TCB la hace inverificable. Minimiza lo confiable; deja fuera lo que no impone política.
"Reetiqueto niveles en caliente sin control"	Viola el principio de tranquilidad; puede crear un canal encubierto. Documenta strong/weak tranquility.

? Preguntas frecuentes

? **¿Por qué BLP permite "escribir arriba" (blind write)?** Porque su único objetivo es la confidencialidad: escribir a un nivel superior no revela secretos hacia abajo. El problema es que puede corromper datos de mayor sensibilidad, por eso BLP no sirve para integridad.

? **¿Clark-Wilson reemplaza a Biba?** No exactamente. Biba es un modelo de retícula orientado a flujo de información; Clark-Wilson es un modelo aplicado y práctico para entornos comerciales que añade transacciones bien formadas y separación de deberes. En certificación se citan como complementarios.

? **¿Dónde veo estos modelos en tecnología real?** SELinux y AppArmor implementan MAC inspirado en BLP/Biba mediante etiquetas de tipo; los hipervisores y TPM materializan la idea de TCB; los anillos 0–3 de x86 y los modos EL0–EL3 de ARM implementan anillos de protección.

? **¿Qué diferencia hay entre monitor de referencia y kernel de seguridad?** El monitor de referencia es el **concepto** abstracto (mediar todo acceso); el kernel de seguridad es su **implementación** concreta dentro de la TCB.

🔗 Referencias

- Chapple, Stewart & Gibson. *(ISC)² CISSP Official Study Guide*, 9.^a ed., Sybex — Dominio 3.
- Bell, D. E. & LaPadula, L. J. *Secure Computer Systems: Mathematical Foundations* (MITRE, 1973).
- Clark, D. & Wilson, D. *A Comparison of Commercial and Military Computer Security Policies* (IEEE S&P, 1987).
- NIST. *An Introduction to Information Security* — [SP 800-12 Rev.1](#).
- Proyecto SELinux — selinuxproject.org.



Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.



Clase anterior

[Clase 315 — MFA y gestión de accesos privilegiados \(PAM\)](#)



Siguiente clase

[Clase 317 — Seguridad física y ambiental](#)